LedgerHouse HMRC Technical Evidence Pack

Date prepared: 2026-07-13

Software: LedgerHouse / KAFS UK Accounting SaaS

HMRC Developer Hub production application: `a830566a-c0c3-4377-9694-5f7d24b71097`

HMRC submission: `08015bda-21b1-415a-b5e6-50fe6fb760e4`

Submission outcome: HMRC Developer Hub confirmed: We have received your request for production credentials.

Purpose

This document records the checks, implementation work, tests and supporting evidence used to complete the HMRC Developer Hub production credentials request for LedgerHouse.

It is intended to be printed or shared with HMRC, a technical reviewer, or an accountant responsible for explaining why the production credentials request was submitted.

Executive Summary

LedgerHouse is a SaaS accounting and practice workflow application. The client uploads invoices, receipts, spreadsheets, PDFs, bank files and other accounting evidence. The accountancy practice or authorised accountant reviews the uploaded data, performs bookkeeping and VAT review work, and prepares reports or HMRC submissions.

Before submitting the HMRC request, the local application was extended and tested in the following areas:

- HMRC OAuth and VAT MTD workflow support.
- HMRC fraud-prevention header generation and validation.
- Customer authorisation privacy and terms pages.
- Application-level encryption of HMRC and bank tokens.
- Tenant access control between client companies.
- Staff-only restrictions for practice, HMRC and Companies House workspaces.
- Client data export for provider switching.
- Security headers and CSP hardening.
- Accessibility review and fixes.
- OWASP ZAP baseline security scan evidence.
- Full local test suite verification.

The latest full local Django test suite passed: `103 tests OK`.

HMRC Checklist Completion

The HMRC Developer Hub terms-of-use checklist showed all sections completed:

- Organisation details.

- Marketing your software.
- Development practices.
- Service management practices.
- Handling personal data.
- Software security.
- Fraud prevention data.
- Customers authorising your software.

The final check-your-answers page was reviewed and then the request was confirmed and sent.

Organisation Details

The production credentials request identified the organisation using Corporation Tax UTR:

- UTR used in request: `6927701370`
- VAT registration: none declared, because the business is not VAT registered.
- Organisation URL used: `https://ledgerhouse.finaccord.pro`

This identifies the software provider. It does not mean future SaaS clients use this UTR. Each client authorises their own HMRC access through OAuth and their data remains separated inside the application.

Marketing Declarations

The HMRC marketing questions were answered on the basis that:

- LedgerHouse does not use HMRC logos in the product, marketing or website.
- LedgerHouse does not display advertising inside the software.
- LedgerHouse is not advertised as HMRC-recognised unless HMRC separately grants that status.
- Customer personal data is not shared for marketing.

Development Practices

The development practice declaration was supported by:

- Django application structure with models, views, migrations, templates and tests.
- Docker Compose local development matching the intended web plus PostgreSQL production architecture.
- Explicit migrations and migration drift checks.
- Automated tests covering accounting logic, access control, uploads, HMRC workflows, reports, VAT and tenant isolation.
- Error handling tests for HMRC API errors and validation failures.
- Evidence documents stored in `docs/compliance/`.

Commands verified during the pass included:

```
docker compose exec -T web python manage.py check
docker compose exec -T web python manage.py makemigrations --check --dry-run
docker compose exec -T web python manage.py test
```

Latest results:

- Django system check: no issues.
- Full test suite: `103 tests OK`.

Accessibility Evidence

Accessibility was reviewed for the main screens used by client and practice users:

- Login.
- Client portal.
- Practice dashboard.
- HMRC VAT workspace.
- Client VAT review.

Evidence file:

- `docs/compliance/hmrc_accessibility_self_certification_2026_07_13.md`

Work performed:

- Added accessible labels for upload controls.
- Added keyboard-submit support for company switcher forms.
- Added visible focus styling.
- Improved foreground/background contrast.
- Corrected dashboard visual semantics.
- Confirmed key pages through automated accessibility checks.

Automated evidence recorded:

- Login page axe scan: `0 violations found`.
- Authenticated key screens with HTML_CodeSniffer WCAG2AA: `0 issues`.
- Authenticated key screens with axe structural pass: `0 issues`.

Remaining production good practice:

- Repeat accessibility scanning after major design changes.
- Add keyboard walkthrough evidence.
- Add screen-reader smoke pass before broad public launch.

Service Management Evidence

Evidence file:

- `docs/compliance/hmrc_service_management_self_certification_2026_07_13.md`

The service management declaration was supported by:

- Authenticated client support/advice request workflow.
- Practice dashboard queue for triaging client questions.
- Business contact email available for external HMRC/developer correspondence.
- Internal process for security incident triage and HMRC notification.

Security incident process:

- Triage the issue through the support/practice queue or business mailbox.
- Identify whether HMRC data, OAuth credentials, API credentials, VAT data or personal data may be affected.
- Notify HMRC Developer Hub Support within 72 hours where HMRC-related data or credentials may be affected.
- Assess ICO reporting duties where personal data may be affected.
- Rotate affected credentials and revoke affected customer authorisations where appropriate.
- Preserve audit evidence and document remediation.

Personal Data Evidence

Evidence file:

- `docs/compliance/hmrc_personal_data_self_certification_2026_07_13.md`

Expected data categories:

- Client company details and contacts.
- Uploaded invoices, receipts, spreadsheets, bank files, payroll files, PDFs and supporting evidence.
- Bank transaction records.
- Accounting journals.
- VAT returns and VAT review decisions.
- Management reports.
- HMRC OAuth tokens and VAT identifiers where a client authorises HMRC access.
- User accounts, audit events and client support requests.

Implemented or verified controls:

- Django authentication for protected screens.
- Staff-only access to practice, HMRC and Companies House workspaces.
- Tenant-specific client access through `TenantUserAccess`.
- Client users blocked from switching into unassigned companies.
- Client users blocked from downloading reports for unassigned companies.
- PostgreSQL row-level-security behaviour covered by automated tests.
- HMRC OAuth tokens and bank consent tokens encrypted in database columns.
- Local secrets excluded from Git.
- CSRF protection on state-changing forms.
- Client/provider-switching data export available as authenticated ZIP.

Important statement:

LedgerHouse does not store customers' HMRC sign-in passwords. HMRC access is through OAuth tokens granted by the customer.

Token Encryption Work

Files added or changed:

- `accounting/crypto.py`
- `accounting/migrations/0015_alter_bankfeedconnection_consent_token_and_more.py`
- `ledgerhouse/settings.py`
- `requirements.txt`

What changed:

- Added `EncryptedTextField`.
- Encrypted HMRC access tokens.
- Encrypted HMRC refresh tokens.
- Encrypted bank consent tokens.
- Added `FIELD_ENCRYPTION_KEY` support for production.
- Added migration to rewrite existing token rows.

Tests verify that raw database values are stored as encrypted `enc:` values while normal model access returns the usable token value.

Tenant Access Control Work

Files added or changed:

- `accounting/models.py`
- `accounting/admin.py`
- `accounting/migrations/0016_tenantuseraccess.py`
- `accounting/views.py`
- `accounting/tests/test_client_portal_workflows.py`

What changed:

- Added `TenantUserAccess`.
- Restricted non-staff client users to assigned companies only.
- Restricted practice, HMRC and Companies House workspaces to staff users.
- Added tests proving non-staff users cannot access practice pages.
- Added tests proving clients cannot switch to or download reports for unassigned companies.

Data Portability Work

Files changed:

- `accounting/reports.py`
- `templates/accounting/client_portal.html`
- `accounting/tests/test_client_portal_workflows.py`

What changed:

- Added client export ZIP.
- Export includes ledger CSVs, VAT records, bank transactions, client request CSVs, evidence index and uploaded evidence files.

- Client portal includes a data export link.
- Tests verify ZIP contents.

This supports HMRC's customer switching/data portability expectations.

Software Security Evidence

Evidence file:

- `docs/compliance/hmrc_software_security_self_certification_2026_07_13.md`

Security controls verified:

- SaaS application with authenticated client and practice workspaces.
- Staff-only workbench restrictions.
- Tenant-level client access restrictions.
- CSRF protection.
- HTTP-only CSRF cookie setting.
- Application-level token encryption.
- Security headers including CSP, Permissions-Policy, X-Frame-Options, X-Content-Type-Options, Referrer-Policy, Cross-Origin-Opener-Policy, Cross-Origin-Embedder-Policy and Cross-Origin-Resource-Policy.
- Inline styles/events removed so CSP does not require `unsafe-inline`.
- Docker/PostgreSQL runtime aligned with deployment architecture.

OWASP ZAP baseline scan:

- Target: `http://host.docker.internal:8000`
- Result: `FAIL-NEW: 0`, `FAIL-INPROG: 0`, `PASS: 60`
- Evidence:

- `docs/compliance/hmrc_zap_baseline_2026_07_13.html` - `docs/compliance/hmrc_zap_baseline_2026_07_13.json`

Warnings were documented as local-development or expected authentication observations rather than confirmed failures.

Production conditions:

- `DEBUG=False`.
- Strong `SECRET_KEY` outside source control.
- `FIELD_ENCRYPTION_KEY` outside source control.
- HTTPS/TLS at reverse proxy.
- Production application server, not Django runserver.
- Restricted PostgreSQL application role from `deploy/create_app_role.sql`.

Fraud Prevention Evidence

Evidence file:

- `docs/compliance/hmrc_fraud_prevention_self_certification_2026_07_13.md`

Relevant HMRC connection method:

- `WEB_APP_VIA_SERVER`

Implemented fraud-prevention headers:

- `Gov-Client-Connection-Method`
- `Gov-Client-Browser-JS-User-Agent`
- `Gov-Client-Device-ID`
- `Gov-Client-Multi-Factor`
- `Gov-Client-Public-IP`
- `Gov-Client-Public-IP-Timestamp`
- `Gov-Client-Public-Port`
- `Gov-Client-Screens`
- `Gov-Client-Timezone`
- `Gov-Client-User-IDs`
- `Gov-Client-Window-Size`
- `Gov-Vendor-Forwarded`
- `Gov-Vendor-License-IDs`
- `Gov-Vendor-Product-Name`
- `Gov-Vendor-Public-IP`
- `Gov-Vendor-Version`

Files changed:

- `accounting/mtd.py`
- `accounting/views.py`
- `static/accounting/fraud_context.js`
- `templates/accounting/hmrc_vat_workspace.html`
- `ledgerhouse/settings.py`
- `accounting/tests/test_hmrc_sandbox.py`

Live HMRC sandbox validator result:

- Endpoint: `https://test-api.service.hmrc.gov.uk/test/fraud-prevention-headers/validate`
- `specVersion`: `3.3`
- `code`: `VALID_HEADERS`
- Message: all headers required for the connection method were supplied and appeared valid.

Production follow-up:

- Set `HMRC_VENDOR_PUBLIC_IP` to the real public ingress address.
- Set `HMRC_VENDOR_VERSION` to the released product version.
- Ensure reverse proxy/load balancer preserves the needed client IP and port information where available.

Customer Authorisation Evidence

Evidence file:

- `docs/compliance/hmrc_customer_authorisation_self_certification_2026_07_13.md`

Answers used:

- Software name: `LedgerHouse`.
- Server location: `In the European Economic Area (EEA)`.
- Privacy policy URL: `https://ledgerhouse.finaccord.pro/privacy/`.
- Terms and conditions URL: `https://ledgerhouse.finaccord.pro/terms/`.

Files added:

- `templates/accounting/privacy.html`
- `templates/accounting/terms.html`

Routes added:

- `/privacy/`
- `/terms/`

Tests verify both public pages render without login.

Production follow-up:

- The policy content should be legally reviewed before broad paid public launch.
- The routes and content are sufficient for the controlled HMRC credentials request.

HMRC VAT Workflow Evidence

The HMRC VAT workflow tests cover:

- HMRC configuration status without exposing secrets.
- HMRC OAuth authorisation URL and scopes.
- OAuth callback token storage.
- Token encryption.
- VAT obligations retrieval.
- Fraud headers passed to obligation retrieval and submission.
- VAT return payload mapping.
- VAT submission recording.
- Client VAT review approval before submission.
- Blocking submission until practice and client review requirements are met.
- HMRC API error handling.

Key file:

- `accounting/tests/test_hmrc_sandbox.py`

Accounting And Client Workflow Tests

The full test suite covers:

- Login flow and client portal rendering.
- Client upload workflows for CSV, XLSX and PDF/evidence.
- Practice dashboard queues.
- Client questions and practice replies/status.
- Evidence review.
- Bank transaction review.
- Ledger review and approval.
- CSV and PDF report generation.
- Client management report view.
- Double-entry journal balancing.
- VAT locks and closed-period protection.
- Tenant isolation/RLS behaviour.
- Bank import idempotency and validation.
- Reconciliation logic.
- Payroll import validation.
- CIS invoice rate validation.
- Open Banking mock sync and tenant isolation.
- Companies House API integration scaffolding.
- End-to-end accounting workflow over six seeded demo tenants.

Latest full test result:

```
Ran 103 tests in 31.586s
OK
```

Observed local warning:

```
Database 'default' connects as a superuser or BYPASSRLS role.
```

This is expected in the local development database. The production plan includes a restricted application role with `NOBYPASSRLS`.

Files Created Or Updated For The HMRC Evidence Pass

Important new files:

- `accounting/crypto.py`
- `accounting/security.py`
- `accounting/migrations/0015_alter_bankfeedconnection_consent_token_and_more.py`
- `accounting/migrations/0016_tenantuseraccess.py`
- `static/accounting/fraud_context.js`
- `templates/accounting/privacy.html`

- `templates/accounting/terms.html`
- `docs/compliance/hmrc_accessibility_self_certification_2026_07_13.md`
- `docs/compliance/hmrc_service_management_self_certification_2026_07_13.md`
- `docs/compliance/hmrc_personal_data_self_certification_2026_07_13.md`
- `docs/compliance/hmrc_software_security_self_certification_2026_07_13.md`
- `docs/compliance/hmrc_fraud_prevention_self_certification_2026_07_13.md`
- `docs/compliance/hmrc_customer_authorisation_self_certification_2026_07_13.md`

Important changed files:

- `accounting/models.py`
- `accounting/admin.py`
- `accounting/mtd.py`
- `accounting/reports.py`
- `accounting/views.py`
- `ledgerhouse/settings.py`
- `ledgerhouse/urls.py`
- `requirements.txt`
- `docker-compose.yml`
- `static/accounting/dashboard.css`
- `templates/accounting/client_portal.html`
- `templates/accounting/hmrc_vat_workspace.html`
- `accounting/tests/test_client_portal_workflows.py`
- `accounting/tests/test_hmrc_sandbox.py`
- `accounting/tests/test_phase2_3.py`

Production Readiness Caveats

The HMRC production credentials request has been submitted. That does not mean broad paid production launch is complete. Before onboarding external paying clients, the following should still be completed:

- HMRC production credentials approval by HMRC.
- Production environment variables, including real secrets and encryption key.
- Production HTTPS deployment.
- Restricted PostgreSQL app role.
- Final legal review of privacy notice, terms and data processing agreement.
- Production backup and restore drill.
- Production monitoring and incident contact route.
- Re-run accessibility and security checks against the final deployed public domain.

Conclusion

The HMRC production credentials request was submitted after implementation and testing work covering the required HMRC checklist areas. The local application passed the full automated test suite, had supporting security and accessibility evidence recorded, had fraud-prevention headers validated through HMRC's sandbox validator, and had public privacy and terms URLs available for the customer authorisation section.

This evidence provides a defensible technical basis for the self-certification answers used in the HMRC Developer Hub production credentials request.